

RESEARCH ARTICLE

ChatPhishDetector: Detecting Phishing Sites Using Large Language Models

TAKASHI KOIDE¹, HIROKI NAKANO¹, AND DAIKI CHIBA¹, (Member, IEEE)

NTT Security Holdings Corporation & NTT Corporation, Tokyo 101-0021, Japan

Corresponding author: Takashi Koide (takashi.koide@security.ntt)

ABSTRACT Large Language Models (LLMs), such as ChatGPT, are significantly impacting various fields. While LLMs have been extensively studied for code generation and text synthesis, their application in detecting malicious web content, particularly phishing sites, remains largely unexplored. To counter the increasing cyber-attacks that leverage LLMs for creating more sophisticated and convincing phishing content, it is crucial to automate detection by harnessing LLMs' advanced capabilities. This paper introduces ChatPhishDetector, a novel system that employs LLMs to identify phishing sites. Our approach involves using a web crawler to collect website information, generating prompts for LLMs based on the gathered data, and extracting detection results from LLM responses. This system enables accurate detection of multilingual phishing sites by identifying impersonated brands and social engineering techniques within the entire website context, without requiring machine learning model training. We evaluated our system's performance using our own dataset and compared it with baseline systems and several LLMs. Experiments using GPT-4V showed exceptional results, achieving 98.7% precision and 99.6% recall, surpassing the detection performance of other LLMs and existing systems. These findings highlight the potential of LLMs for protecting users from online fraudulent activities and provide crucial insights for strengthening defenses against phishing attacks.

INDEX TERMS Large language models, phishing sites, social engineering.

I. INTRODUCTION

Large Language Models (LLMs) [1], [2], [3], [4], such as ChatGPT [5], are revolutionizing various domains, including natural language understanding, generation, and interaction. While previous research has focused on exploring the capabilities of LLMs for tasks such as code generation and text synthesis, their potential in analyzing and detecting malicious web content, particularly phishing sites, remains largely unexplored. To counter the growing threat of automated cyber-attacks, including those potentially involving LLMs [6], [7], [8], [9], it is crucial to automate the detection of malicious web content by leveraging their versatility.

Phishing sites pose a significant threat to Internet users. They employ social engineering (SE) techniques [10], [11], [12] and masquerade as legitimate platforms, deceiving users

into revealing sensitive information or causing financial harm. Attackers employ email, short message service (SMS), and web advertisements to lure users and redirect them to phishing sites through malicious links [13], [14]. Two key components characterize phishing sites: (1) imitation of legitimate services using official logos and branding, and (2) utilization of social engineering techniques to manipulate user actions. The phishing sites targeted in this study exhibit one or both of these components. By mimicking legitimate services, phishing sites deceive users and gain their trust [15], [16]. These websites frequently impersonate legitimate platforms such as online banking services [17], e-commerce sites [18], and social media platforms [19]. Additionally, they may create a sense of urgency or fear by displaying fake malware infection warnings or account problems, or generate interest by presenting fictitious rewards [20]. Through these social engineering techniques, users are misled into providing sensitive information such as login credentials and credit card numbers. Furthermore, various user actions may be

The associate editor coordinating the review of this manuscript and approving it for publication was Loris Belcastro¹.

induced, including sending cryptocurrency, contacting fake technical support centers [21], or downloading applications and executable files [11].

Although various methods have been employed to detect phishing sites, two main problems persist. The first is the need to learn targeted brands and modify detection logic accordingly for phishing sites. For example, it is necessary to collect logo images that phishing sites misuse in advance or to create rules to detect them according to domain squatting techniques. The second problem is the difficulty in analyzing the context of psychological manipulation induced by social engineering techniques in detail. While some studies have employed keyword matching and deep learning-based analysis [22], [23], few attempts have been made to automatically analyze and comprehend the various contexts of psychological manipulation by examining the entire content of a website.

In this study, we propose a novel system called ChatPhishDetector, designed to investigate the potential capabilities of LLMs in detecting phishing sites. Our system employs a web crawler to collect website information and generate prompts [24], [25] for LLM analysis. This approach enables the identification of SE techniques and brand impersonation without requiring extensive training data for machine learning models. To the best of our knowledge, this is the first study to systematically examine the effectiveness of LLMs in identifying phishing sites. To evaluate the performance of our system, we conducted a comparative experiment between several LLMs and existing systems, using a diverse dataset curated from multiple sources. The experimental results using GPT-4 with vision capabilities (GPT-4V) [26] demonstrated exceptional performance, achieving a precision of 98.7% and a recall of 99.6%. Our analysis revealed that GPT-4 and GPT-4V excelled in assessing the suspiciousness of domain names, identifying SE techniques from website content, and providing comprehensive phishing detection results by considering multiple factors. These findings underscore the significant potential of LLMs in automating the detection of phishing sites, potentially replacing manual efforts to generate phishing-related threat intelligence, and assisting users in identifying the risks associated with encountered phishing sites.

In summary, we make the following contributions:

- We propose a novel system called ChatPhishDetector for detecting phishing sites using LLMs. Our system employs automated prompt generation based on web crawling results to classify websites as phishing or legitimate.
- We present a comprehensive experimental evaluation of our system and compare its performance against existing phishing detection systems. Our results demonstrate that GPT-4V achieved the highest precision (98.7%) and recall (99.6%) in identifying phishing sites. Additionally, we evaluated several LLMs and found that open-source models such as Llama 3 70B

offer accuracy comparable to proprietary models like GPT-4. This highlights the potential for cost-effective, high-performance phishing detection using open-source LLMs.

- We present a detailed analysis of responses generated by LLMs and explore why LLMs exhibit advanced capabilities in analyzing phishing sites. Our findings revealed that GPT-4/GPT-4V excel in identifying suspicious domain names associated with brand impersonation, finding SE techniques employed in web content, and prioritizing multiple factors for comprehensive phishing detection.

The remainder of this paper is organized as follows. Section II reviews related work on phishing detection. Section III introduces our proposed system, ChatPhishDetector, detailing its architecture and methodology. Section IV describes the dataset used for evaluation, including its composition and preparation process. Section V presents our experimental results, comparing ChatPhishDetector's performance with existing systems and analyzing its effectiveness across different models and modes. Section VI discusses the implications of our findings, addresses limitations, and explores potential future directions. Finally, Section VII concludes the paper, summarizing our key contributions and insights.

II. RELATED WORK

Extensive research has been conducted to understand the characteristics, techniques, and fundamental mechanisms employed by attackers on phishing sites. Researchers have analyzed the design, structure, and content of these sites, identified common patterns, and developed methods for detecting phishing sites. These studies contribute to improving security practices, educating users about potential threats, and devising effective strategies to mitigate online fraud and risks. Previous studies such as Abdelnabi et al. [27], Lin et al. [15], and Liu et al. [16] detect the abuse of logo images by identifying and comparing them with legitimate ones, or extract features from the overall appearance of web pages to analyze their similarity. While these deep learning-based methods are effective in detecting phishing sites created by copying HTML or reusing logos, they cannot detect phishing sites that use their own logos or do not impersonate brands. Our system aims to identify phishing sites that use SE techniques by analyzing the context of the web page, allowing for the detection of different types of phishing sites, not limited to the misuse of branding. Zhang et al. [28] proposed a content-based anti-phishing framework that combines textual and visual features using a Bayesian approach. Their system uses a text classifier based on naive Bayes, an image classifier using Earth Mover's Distance for visual similarity, and a Bayesian fusion algorithm to combine results from both classifiers. Our system, on the other hand, uses LLMs to infer the phishing site classification results,

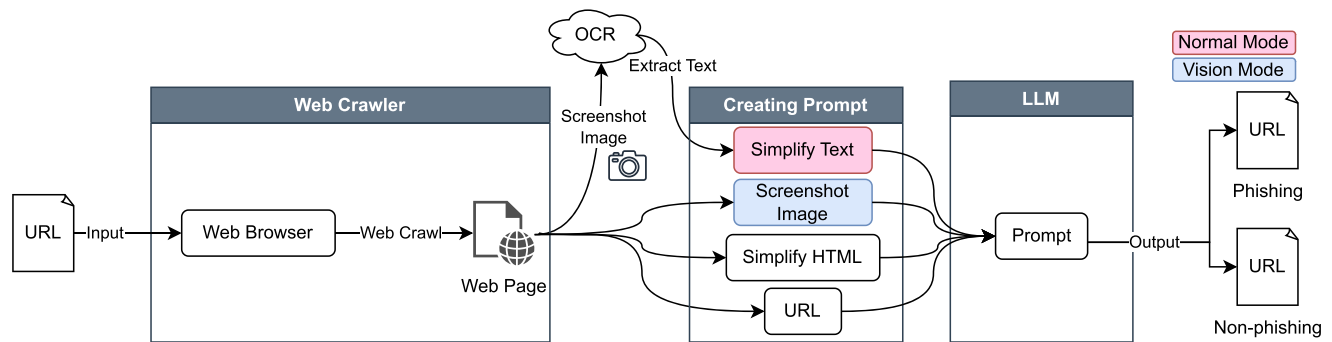


FIGURE 1. Overview of ChatPhishDetector.

enabling a comprehensive phishing assessment that includes reasoning and confidence scores.

Methods have been proposed to detect domain squatting, where attackers obtain domain names similar to legitimate service domain names. Nikiforakis et al. [29], Quinkert et al. [30], Kintis et al. [31], Agten et al. [32], and dnstwist [33] have proposed techniques that use rule-based approaches or machine learning models to identify malicious domain names by considering various factors such as minor variations, the inclusion of brand names, and changes in top-level domains. LLMs showed high capabilities against domain squatting, as demonstrated in our evaluation experiments. They successfully detected minor character differences and fake domain names containing brand names. Methods also exist that use TLS certificates to detect phishing sites. Kim et al. [34], Bijmans et al. [17], and Drichel et al. [35] have proposed such approaches that use machine learning algorithms to analyze features derived from TLS certificates or certificate transparency logs to detect phishing sites.

There have been attempts to apply LLMs to cybersecurity. One such example is VirusTotal Code Insight [36], which is based on Google's security-focused LLM, Sec-PaLM. This model can explain the purpose and functionality of malware code in natural language, allowing security experts to gain a general understanding of the code's intentions. Trad and Chehab [37] compared prompt engineering and fine-tuning techniques for LLMs in phishing URL detection, finding that task-specific fine-tuned LLMs outperformed prompt-engineered LLMs. In contrast, our system includes not only the URL, but also HTML, screenshots, and carefully designed prompts to achieve superior detection accuracy. Meng et al. [38] proposed CHATAFL, an LLM-guided protocol fuzzing engine that outperformed state-of-the-art fuzzers in terms of state and code coverage and discovered nine previously unknown vulnerabilities in widely-used protocol implementations. Liu et al. [39] proposed PhishLLM, a framework for phishing site detection based on brand identification and credential-requiring page recognition. Their method employs OCR and image captioning techniques to input logo information into an LLM for

brand inference, offering flexibility and versatility compared to reference-based brand identification approaches. Our system uses LLMs for both brand identification and comprehensive phishing determination, including explanation. This approach enables accurate detection of a wide range of phishing sites, including those without prominent brand logos. Roy et al. [40] conducted research on fine-tuning an DistilBERT specifically for phishing site detection. While their approach of extracting crucial tags from HTML source code to capture phishing characteristics aligns with our methodology, our system distinguishes itself by incorporating image input to the LLM. This modality allows our system to detect visual social engineering techniques employed in phishing sites, enhancing its overall effectiveness.

III. CHATPHISHDETECTOR

We propose ChatPhishDetector, a system that uses LLMs to analyze the content of websites and URLs to detect phishing sites. Our system takes advantage of LLMs' highly accurate contextual understanding to precisely identify textual and visual representations involving SE techniques, as well as inconsistencies between brands deceived by the websites and domain names. By leveraging LLMs pre-trained on extensive data, our system has the potential to detect various phishing sites across the languages the model has been trained on, without requiring specific learning from collected phishing sites. In this manner, the system addresses two problems present in previous studies. An overview of the system is illustrated in Figure 1. Our system uses a web crawler to access the input URL and obtain information from the visited website, such as a screenshot image, HTML, and the URL. This information is used to create a prompt for input into LLMs, which then determines whether the website is a phishing site or a non-phishing site. Our system has two modes: *Normal mode*, which operates with LLMs that accept text input only, and *Vision mode*, which operates with multimodal LLMs that accept both text and images as input.

We formally define the phishing detection as a classification problem. Let $W = w_1, w_2, \dots, w_n$ be a set of websites, where each website w_i is represented by a tuple (u_i, h_i, s_i) , where u_i is the URL, h_i is the HTML content, and s_i is

the screenshot image of the website. The phishing detection problem can be formulated as a binary classification task:

$$f : W \rightarrow 0, 1 \quad (1)$$

where f is the classification function, and the output 1 indicates a phishing website, while 0 indicates a legitimate website.

A. WEB CRAWLING

We implement a web crawler that automates Google Chrome using Chrome DevTools Protocol [41] to visit websites and collect information. This approach was chosen over popular tools like Selenium or Puppeteer to mitigate the risk of bot detection. Given an input URL, the web crawler accesses the page and retrieves the URL of the reached web page (the final destination after any redirects), the HTML after JavaScript execution, and captures a screenshot image. The reason for obtaining the HTML after JavaScript execution (Browser-rendered HTML) is that some phishing sites employ obfuscated JavaScript to generate DOM elements as a means to evade analysis. As a result, it becomes challenging to analyze any traces of phishing solely based on the HTML before JavaScript execution. The web crawler is configured to emulate two different environments: Google Chrome on Windows and Safari on iPhone. These configurations include specifying the *UserAgent* and browser size for each environment.

B. PROMPT ENGINEERING

We describe the process of generating a prompt for detecting phishing sites. The template for the prompt is shown in Prompt Template 1. The purpose of this prompt is to provide website information to LLMs and control the inference process to determine whether it is a phishing site or not. We create the template based on the Chain of Thought (CoT) prompting technique [25], [42]. The CoT is a prompting technique that encourages LLMs to explain their reasoning. The CoT technique has been shown to be effective in improving performance on a variety of reasoning tasks, such as arithmetic and symbolic reasoning. The task of phishing site detection is divided into four subtasks, which facilitate the execution of specific reasoning processes. These subtasks are as follows:

- 1) Analyze whether the website contains SE techniques that deceive or attract users. The prompt provides typical SE techniques commonly used by phishing sites, such as cash prizes, fake malware infection warnings, account problems, and postal parcel issues. We instruct LLMs that the presence of these factors without context in a non-login state indicates a high probability of a phishing site.
- 2) Extract the brand name of the website. Phishing sites may be created by copying resources such as HTML and images from legitimate sites, making it difficult to determine their authenticity based on HTML alone.

Prompt Template 1

Note: **Normal mode** is indicated with a red marker, and **Vision mode** is indicated with a blue marker.

You are a web programmer and security expert tasked with examining a web page to determine if it is a phishing site or a legitimate site. To complete this task, follow these sub-tasks:

1. Analyze the HTML, URL, and **OCR-extracted text**, **screenshot image** for any SE techniques often used in phishing attacks. Point out any suspicious elements found in the HTML, URL, or text.
2. Identify the brand name. If the HTML appears to resemble a legitimate web page, verify if the URL matches the legitimate domain name associated with the brand, if known.
3. State your conclusion on whether the site is a phishing site or a legitimate one, and explain your reasoning. If there is insufficient evidence to make a determination, answer "unknown".
4. Submit your findings as JSON-formatted output with the following keys:
 - **phishing_score**: int (indicates phishing risk on a scale of 0 to 10)
 - **brands**: str (identified brand name or None if not applicable)
 - **phishing**: boolean (whether the site is a phishing site or a legitimate site)
 - **suspicious_domain**: boolean (whether the domain name is suspected to be not legitimate)

Limitations:

- The HTML may be shortened and simplified.
- **The OCR-extracted text may not always be accurate.**

Examples of social engineering techniques:

- Alerting the user to a problem with their account
- Offering unexpected rewards
- Informing the user of a missing package or additional payment required
- Displaying fake security warnings

URL:

{URL}

HTML:

``` {Browser-rendered HTML} ```

**Text extracted using OCR:**

``` {OCR-extracted text} ```

Therefore, LLMs are prompted to confirm whether the URL corresponds to the legitimate one.

- 3) Determine whether the website is a phishing site or not, and explicitly state the rationale for the decision. We intend that providing a detailed explanation will

improve the accuracy of the response and facilitate human analysis.

- 4) Generate output in JSON format. If the website uses SE techniques, LLMs are expected to return *phishing* as true. If the LLM identifies the brand name and confirms that its domain name is different from the legitimate one, *suspicious_domain* is expected to be true. In addition, a *phishing_score* is generated, which ranges from 0 to 10.

These tasks can be formalized as a sequence of reasoning steps:

$$\mathbf{P} = [p_1, p_2, p_3, p_4] \quad (2)$$

where:

- p_1 : Analyze the HTML, URL, and image for SE techniques
- p_2 : Extract the brand name
- p_3 : Determine whether the site is phishing or legitimate
- p_4 : Generate JSON-formatted output

The system creates a prompt by substituting (i) URL, (ii) HTML, and (iii) text extracted from a screenshot image using optical character recognition (OCR) into this prompt template. Some phishing sites evade HTML-based phishing site analysis by not including specific brand names or text in the HTML. For example, they display brand information (logos or headings) in image files or canvas elements. To incorporate such information into the prompt, we employ text extraction from screenshot images using OCR. In Vision mode, the system sends screenshot images directly to LLMs instead of OCR-extracted text. To classify detection results from the responses, we define a response as indicating a phishing site if either the value of the *phishing* key or the *suspicious_domain* key is true. Conversely, a response is labeled as non-phishing if both keys are false.

Depending on the length of HTML and OCR-extracted text, some websites may exceed LLMs' token (characters or words used for processing by LLMs) limit. For example, GPT-3.5-turbo and Llama 2 have a 4k token limit. In fact, the median token count for HTML in our dataset (see Section IV) is 30,398 (with a median of 74,937 for non-phishing pages), indicating that a large number of web pages exceed this token limit. To compare the performance of different LLMs under the same conditions, we simplify the HTML and OCR-extracted text to fit within 4k tokens in this study. Since this prompt template consumes 362 tokens, we allocate 300 tokens for the response and set the maximum tokens for HTML, OCR-extracted text, and URL to 2,500, 500, and 300, respectively. In the following sections, we describe the specific processes to simplify the HTML and OCR-extracted text.

C. SIMPLIFYING HTML

The system simplifies the HTML while preserving essential information for phishing detection and brand identification. Elements located at the top of the HTML, such as the `title`

Algorithm 1 Simplifying HTML

Require: inputHTML: Input HTML

Ensure: processedHTML: Processed HTML

```

1: function SimplifyHTML(inputHTML)
2:   Remove style, script, and comment elements from
     inputHTML
3:   processedHTML  $\leftarrow$  Result after removal
4:   if lengthToken(processedHTML) < 2500 then
5:     return processedHTML
6:   end if
7:   Unwrap elements except for important tags
8:   Remove elements without text content
9:   Shorten href in a tags and src in img tags
10:  processedHTML  $\leftarrow$  Result after removal
11:  if lengthToken(processedHTML) < 2500 then
12:    return processedHTML
13:  end if
14:  while lengthToken(processedHTML) > 2500 do
15:    Remove an HTML element from the midpoint of
       the processedHTML
16:    processedHTML  $\leftarrow$  Result after removal
17:  end while
18:  return processedHTML
19: end function

```

and the `meta description` element, primarily contain cues for determining the services provided by the website. Additionally, the `form` element used for inputting login information and text displayed on the page are crucial for analyzing the role of the website. To retain the amount of such information while minimizing the overall HTML length, we follow the steps outlined in Algorithm 1. This process removes HTML elements, such as style, script, and comment tags, that have low relevance and a high number of tokens. Subsequently, the system unwraps HTML elements other than the important tags listed as `head`, `title`, `meta`, `body`, `h1`, `h2`, `h3`, `h4`, `h5`, `h6`, `p`, `strong`, `a`, `img`, `hr`, `table`, `tbody`, `tr`, `th`, `td`, `ol`, `ul`, `li`, `ruby`, and `label`. Unimportant elements are eliminated, and their child elements are incorporated into their parent elements. Next, our system removes HTML elements that do not contain text enclosed within tags. We also shorten the `src` attribute `img` elements encoded in base64 and the `href` attribute of `a` elements containing lengthy URLs. The system repeatedly removes an HTML element located in the middle of the HTML until the number of tokens falls below the maximum number of tokens.

The HTML simplification process can be mathematically formulated as follows. Let H be the original HTML document, $T(H)$ be the function that returns the number of tokens in H , and M be the maximum number of tokens. Our goal is to find a simplified HTML document $S(H)$ such that:

$$T(S(H)) \leq M \quad (3)$$

D. SIMPLIFYING OCR-EXTRACTED TEXT

Our system also simplifies OCR-extracted text in normal mode. Specifically, it examines the font size of the identified text by the OCR and removes sentences starting from the smallest font size. This process is repeated until the number of tokens in the text falls below the predefined threshold.

IV. DATASET

In this section, we explain the process of creating a comprehensive and high-quality dataset for our experiment, addressing the limitations inherent in existing phishing site datasets. Existing publicly available datasets often suffer from several limitations. These include lack of representation of the latest phishing threats, linguistic bias (e.g., predominantly English-language sites), and a high prevalence of duplicate entries where phishing sites differ only in URL while maintaining similar visual content. To overcome these limitations, we employed a multi-faceted strategy, combining data from various sources to construct a high-quality, diverse dataset. Our approach aimed to mitigate the aforementioned limitations and provide a more representative sample of contemporary phishing threats. The resulting dataset comprises a total of 1,000 phishing sites and an equal number of non-phishing sites.

A. PHISHING SITES

To collect phishing sites, we used OpenPhish [43] and PhishTank [44], which are phishing intelligence sources, and CrowdCanary [45], a method for extracting phishing-related posts from Twitter using machine learning models. CrowdCanary uses keyword-based filters such as “phishing” and “scam” and extracts URLs from posts associated with phishing encountered by victims or observed by security experts. From March to April 2023, we collected URLs from these three sources and used them as seed URLs to crawl. This enabled us to obtain a wide range of phishing sites not limited to incoming channels such as email, SMS, and web advertisements. Next, we accessed the seed URLs using the web crawler described in Section III-A. To ensure the integrity of our dataset, we excluded websites with incomplete rendering and image loading. We then selected phishing sites that contained one of the following two elements as candidates for the dataset.

- Websites that display logos or brand names associated with well-known services or that visually resemble legitimate sites.
- Websites employing SE techniques, such as presenting false information (e.g., fake rewards, virus infection alerts, account issues), to generate a sense of urgency or interest.

Datasets used in previous studies of phishing site detection may contain large amounts of data with different URLs but the same appearance and HTML. In this study, to eliminate bias in the evaluation due to duplication, we created a dataset by excluding all but one of the similar phishing sites

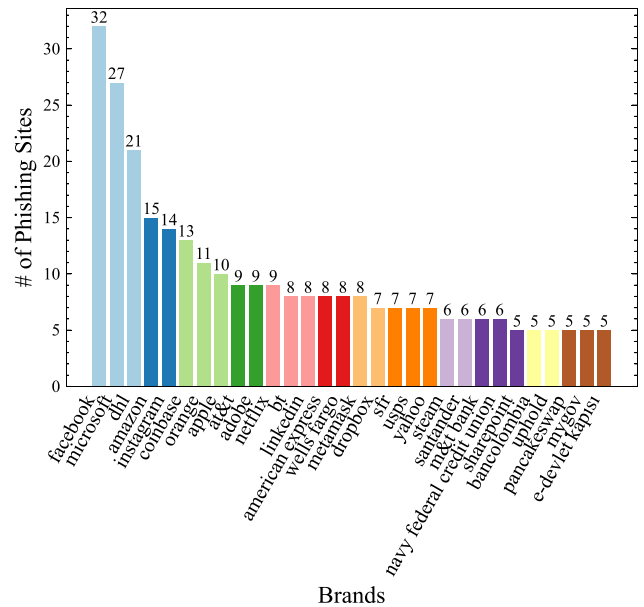


FIGURE 2. Top 30 brands targeted by phishing sites.

found among those we collected. Criteria for determining similarity include fully qualified domain name (FQDN), page title, website appearance (calculated in perceptual hash), and text content. However, if the websites had the same appearance but different languages, they were retained.

As a result of the above analysis, we obtained a dataset of 1,000 phishing sites with unique 1,000 FQDNs. These phishing sites targeted a total of 147 legitimate service brands (see Appendix). We identified 32 phishing sites that did not contain any brand information. Figure 2 shows the top 30 brands used by phishing sites in the dataset. We extracted text from the screenshot images using OCR for the normal mode. In this paper, we used Azure Cognitive Service [46] to streamline the OCR process for multilingual websites. We identified the languages of the OCR-extracted text using langdetect [47], a language detection library, revealing that the 1,000 phishing sites were distributed across 22 different languages. Figure 3 illustrates the number of phishing sites in each language.

Phishing sites vary in design; some are exact clones of legitimate sites, while others have original content or incorporate elements such as layouts and logos from legitimate sites. These diverse phishing sites are difficult to detect using existing systems that rely primarily on image similarity to their legitimate sites. We identified 172 phishing sites (17.2%) in our dataset that did not closely resemble their legitimate sites. Examples of such phishing sites include those that mimic popular platforms such as Amazon or Netflix and employ gift card scams. There are also phishing sites that impersonate Facebook logos or disguise Windows Defender scan results, displaying fake account suspensions or virus infection warnings.

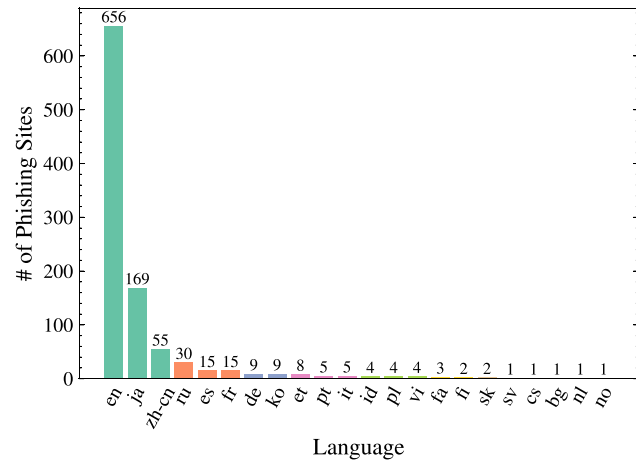


FIGURE 3. Language distribution of phishing sites.

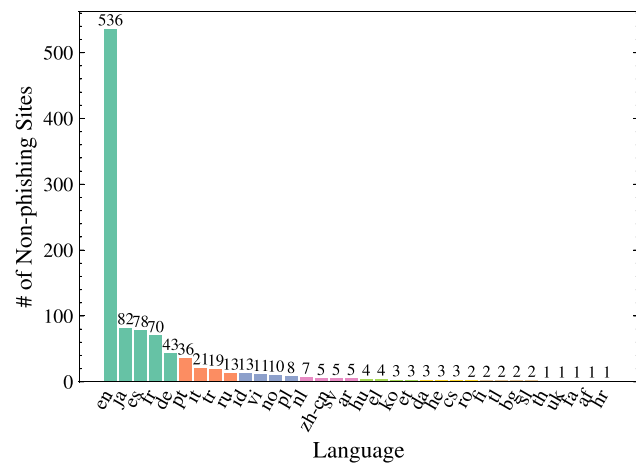


FIGURE 4. Language distribution of non-phishing sites.

B. NON-PHISHING SITES

We collected an equal number of websites as phishing sites for non-phishing sites. The seed URLs consisted of legitimate websites for the 153 brands targeted by phishing sites, as well as the top 2k domain names from the Tranco list [48]. From the legitimate sites of the 153 brands, we extracted the URLs of their homepages and, if available, the login pages (a total of 236 URLs with 196 FQDNs). After crawling the Tranco top 2k, we successfully accessed 1,661 URLs. The Tranco top sites include certain categories such as adult content, illegal downloads/streaming, and gambling. Websites within these categories may not always be benign, as they potentially lead to phishing sites through malicious advertising. Consequently, we have excluded such websites from our analysis. The breakdown of excluded websites is as follows: 28 porn, 3 gambling, and 9 illegal sites. The remaining 764 websites (out of 1,000 non-phishing sites) were randomly selected from the crawled Tranco top sites. The non-phishing sites are distributed across 34 languages.

Figure 4 presents the distribution of non-phishing sites across different languages.

Prompt Template 2

You are a web programmer and security expert tasked with examining a URL to determine if it is a phishing site or a legitimate site. Submit your findings as JSON-formatted output with the following keys:

- phishing_score: int (indicates phishing risk on a scale of 0 to 10)
- brands: str (identified brand name or None if not applicable)
- phishing: boolean (whether the site is a phishing site or a legitimate site)
- suspicious_domain: boolean (whether the domain name is suspected to be not legitimate)

URL:
{URL}

C. SIMPLIFYING HTML AND OCR-EXTRACTED TEXT

We simplified the collected HTML and OCR-extracted text of phishing sites and non-phishing sites using the process explained in Section III-C and III-D. The median token count in the HTML of non-phishing sites was 74,937 before simplification, while it was 8,275 for phishing sites. In general, non-phishing sites have a higher token count. One reason for this difference is that non-phishing sites often implement a variety of sophisticated features through complex JavaScript code or use large platforms, while phishing sites have only the minimum functionality necessary to deceive users or steal sensitive information. Of the 2,000 sites in the data set, 980 exceeded the maximum token limit of 32K tokens for the ChatGPT model used in this study. The median number of tokens in the OCR-extracted text from non-phishing websites was 296, while for phishing websites, it was 122. Similar to the HTML comparison, non-phishing sites tend to have a higher number of tokens.

V. EVALUATION

To validate the detection accuracy of ChatPhishDetector, we performed experiments with different LLMs, different modes, and conducted comparisons with existing systems.

A. EXPERIMENTAL SETUP

In this section, we provide an explanation of LLMs and existing phishing detection systems used in our evaluation experiments.

1) MODELS

ChatGPT is the most well-known LLM developed by OpenAI. We used the Azure OpenAI API [50] for accessing gpt-4-0314 (referred to as GPT-4) and gpt-3.5-turbo-0301 (referred to as GPT-3.5) in

TABLE 1. Comparison of performance metrics. URL, HTML, and Image indicate the types of information accepted as input, while Phishing and Non-phishing represent classification targets.

System	Mode	Model	Precision	Recall	Accuracy	F-measure	URL	HTML	Image	Phishing	Non-phishing
ChatPhishDetector	Vision	GPT-4V	98.7%	99.6%	99.2%	99.2%	✓	✓	✓	✓	✓
		Gemini Pro 1.0	78.9%	99.1%	89.1%	87.9%	✓	✓	✓	✓	✓
	Normal	GPT-4	98.3%	98.4%	98.4%	98.4%	✓	✓	✓	✓	✓
		GPT-3.5	98.3%	86.7%	92.6%	92.1%	✓	✓	✓	✓	✓
		Llama 2 70B	78.4%	66.4%	74.1%	71.9%	✓	✓	✓	✓	✓
	Simple	Gemini Pro 1.0	90.5%	95.6%	93.2%	93.0%	✓	✓	✓	✓	✓
		GPT-4	98.4%	75.5%	87.2%	85.5%	✓			✓	✓
		GPT-3.5	98.6%	77.5%	88.2%	86.8%	✓			✓	✓
dnstwist [33]	-	-	31.3%	-	-	-	✓			✓	
Phishpedia [15]	-	-	26.0%	-	-	-			✓	✓	
PhishStorm [49]	-	-	52.0%	75.1%	52.8%	61.4%	✓			✓	✓

normal mode, and gpt-4-vision-preview (referred to as GPT-4V) in vision mode.

Gemini Pro is an LLM developed by Google DeepMind [51]. We used Gemini Pro 1.0 in normal mode and vision mode, accessed via the Google Cloud API.

Llama 2 is an open-source LLM, and we chose to use its most high-performance model (Llama-2-70b-chat-hf). We ran the Llama 2 model using Ubuntu Server 20.04 LTS and an Nvidia A100 GPU with 4-bit quantization. We queried Llama 2 with the same prompts as the other models in normal mode.

Simple mode uses a simplified prompt with only the URL assigned, to compare with the well-designed prompts in our system. The simplified prompt is demonstrated in Prompt Template 2. We conducted experiments using both GPT-4 and GPT-3.5 for the simple Mode.

2) BASELINE SYSTEMS

We chose dnstwist [33], Phishpedia [15], and PhishStorm [49] as baseline systems because they have been widely used in previous studies [16], [34], [52], [53], [54] for phishing detection. Since these systems determine legitimate sites by matching against prepared URL allow lists, we focused our comparison only on their ability to predict phishing sites (true positives and false negatives).

dnstwist [33] is an open-source tool designed to generate and validate domain names similar to legitimate domain names that may be abused for phishing sites, such as typo-squatting and brand impersonation. We generated such domain name strings using domain names from non-phishing sites in our dataset as seeds. We compared the strings, excluding the TLDs, to the domain names of the phishing sites in our dataset. If there was a partial match, we considered the phishing detection successful.

Phishpedia [15] is an open-source tool to identify phishing sites from screenshot images by training on brand logo images. To train the model, we added additional brand logo images from the non-phishing sites in our dataset to the publicly available logo images in Phishpedia's code. We used Phishpedia to analyze screenshot images of phishing sites in our dataset. If a brand logo image was detected, we considered the phishing detection successful.

TABLE 2. Detection results by mode and model for ChatPhishDetector. TP, TN, FP, FN represent True Positives, True Negatives, False Positives, and False Negatives, Respectively.

Mode	Model	TP	TN	FP	FN
Vision	GPT-4V	991	986	13	4
	Gemini Pro Vision	789	993	7	211
Normal	GPT-4	984	983	17	16
	GPT-3.5	867	985	15	133
	Llama 2 70B	664	817	183	336
Simple	Gemini Pro	905	958	42	95
	GPT-4	755	988	12	245
	GPT-3.5	775	989	11	225

PhishStorm [49] is a phishing URL detection system that analyzes the lexical features of URLs to identify phishing attempts. PhishStorm leverages 12 features characterizing the relationships between words in the URL and domain popularity. These features are then used in a Random Forest classifier to distinguish between phishing and legitimate URLs. We implemented PhishStorm following the description in the original paper and trained a Random Forest classifier on the dataset published by the authors. For evaluation, we used PhishStorm to analyze the URLs of the phishing sites in our dataset and considered a detection successful if the URL was classified as phishing.

B. SUMMARY OF RESULT

1) PERFORMANCE COMPARISON

Table 1 provides a comparative analysis of the performance metrics for the ChatPhishDetector across various models (GPT-4V/4/3.5, Llama 2, and Gemini Pro/Pro Vision), modes (vision, normal, and simple), and baseline systems (dnstwist and PhishPedia). Precision ($= \frac{TP}{TP+FP}$), Recall ($= \frac{TP}{TP+FN}$), Accuracy ($= \frac{TP+TN}{TP+TN+FP+FN}$), and F-measure ($= 2 \times \frac{Precision \times Recall}{Precision+Recall}$) were used as performance metrics. Table 2 shows the detailed detection results of ChatPhishDetector for each mode and model. GPT-4V failed to provide responses for five phishing sites and one non-phishing site in our dataset. This occurred because our prompts triggered Azure OpenAI's content management policy. We successfully disabled content filters in the API to allow GPT-4 and GPT-3.5 to process all of our prompts. However, it appears that

this disabling setting did not effectively work for GPT-4V at the time. GPT-4V (vision mode) demonstrated remarkable performance in classifying both phishing and non-phishing sites, achieving a precision of 98.7% and a recall of 99.6%, with only 4 false negatives and 13 false positives. GPT-4 (normal mode) also outperformed the other models with 98.3% accuracy and 98.4% recall. The classification performance of GPT-4 and GPT-3.5 for non-phishing sites was comparable, with low false positives, and both had 98.3% precision. However, for phishing site classification, GPT-4 significantly improved with a recall of 98.4% compared to GPT-3.5's 86.7%. Interestingly, unlike with GPT-4V and GPT-4, the vision mode did not always lead to higher accuracy compared to the normal mode for other models. Gemini Pro 1.0 Vision had a lower accuracy of 89.1% compared to Gemini Pro 1.0, which achieved 93.2% accuracy. Despite Gemini Pro 1.0 Vision having fewer false positives (7), its substantial number of false negatives (211) indicated a bias towards positive responses. A potential explanation for this performance discrepancy is Gemini Pro 1.0 Vision's limited proficiency in recognizing non-English text from images. Furthermore, the ability to integrate visual and textual data plays a critical role in accurately identifying phishing attempts. Llama 2 demonstrated lower effectiveness compared to other models in the normal mode, achieving an accuracy of only 74.1%. This may be attributed to insufficient training data and model performance, particularly considering Llama 2's primary training on English data and its limited capability in interpreting non-English text and identifying non-English brands. A comparison between normal and simple modes revealed a significant improvement in accuracy for both GPT-4 and GPT-3.5. This improvement is attributed to the normal mode's use of well-considered custom prompts to analyze a combination of URLs, HTML, and screenshot images. It enhances the ability to distinguish phishing sites compared to the simple mode, which relies solely on URLs as input. In Section IV-A, we discussed the phishing sites in the dataset that do not closely resemble legitimate sites. When analyzing the true positives in this data, GPT-4/GPT-4V successfully identified all 172 phishing sites (100%), while GPT-3.5 detected 171 phishing sites (99.4%). Our system demonstrated high accuracy in detecting these phishing sites by analyzing the context of brand impersonation and social engineering techniques, rather than relying solely on comparisons with legitimate sites using screenshot images.

2) BASELINE SYSTEMS

Since dnstwist and Phishpedia focus exclusively on the prediction of phishing sites, we only calculated the precision for these systems. The results showed a precision of 31.3% for dnstwist and 26.0% for Phishpedia. For example, dnstwist successfully detected phishing sites using the domain squatting technique such as `microsoft` (a transformation of `microsoft`) in `exceklcmicrosoftprotection.pages[.]dev`.

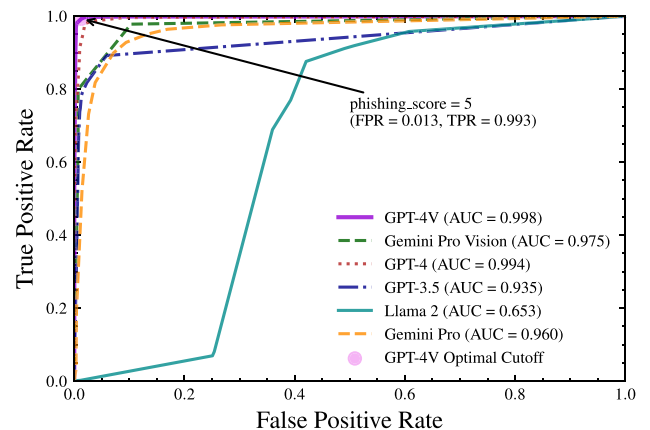


FIGURE 5. ROC Curve for phishing classification based on *phishing_score*.

Phishpedia is useful for detecting phishing sites with logo images, even if the page design differs from the legitimate site. Our system, on the other hand, had broad coverage and was able to identify phishing sites even when they did not have official logos. PhishStorm had a recall of 75.1%, comparable to ChatPhishDetector's simple mode, indicating effective detection of phishing domains with original brand names and suspicious URL paths. However, its precision (52.0%) and accuracy (52.8%) were suboptimal. While PhishStorm performed well on brands present in its training data, it showed limitations in identifying phishing sites for unfamiliar brands or those lacking distinctive domain features. This weakness can be attributed to its reliance on URL input alone.

The lower recall in Phishpedia (compared to the original paper's 87.1% [15]) is primarily due to differences in the datasets. The Phishpedia dataset, which reflects the real-world prevalence of phishing sites, contains many duplicate data. In contrast, we eliminated duplicate screenshots from our dataset; as a result, our dataset contains a wide variety of phishing sites, including those that do not contain brand logos or that do not impersonate brands that are not among the most popular. It is possible to attribute the observed performance gap to these dataset differences. Based on these results, the subsequent sections will provide a detailed analysis of the detection capability of our system.

3) PHISHING CLASSIFICATION USING PHISHING_SCORE

While the above results were calculated based on the values of the *phishing* and *suspicious_domain* keys, we can also classify the responses by selecting an appropriate threshold for the *phishing_score* value. By incrementing the threshold by 1, we calculated the true positive rate and false positive rate and plotted the receiver operating characteristics (ROC) curve, as illustrated in Figure 5. The optimal cutoff values for *phishing_score*, calculated using the Youden's J statistic ($J = \frac{TP}{TP+FN} + \frac{TN}{TN+FP} - 1$), were 5, 1, 3, 1, 6, and

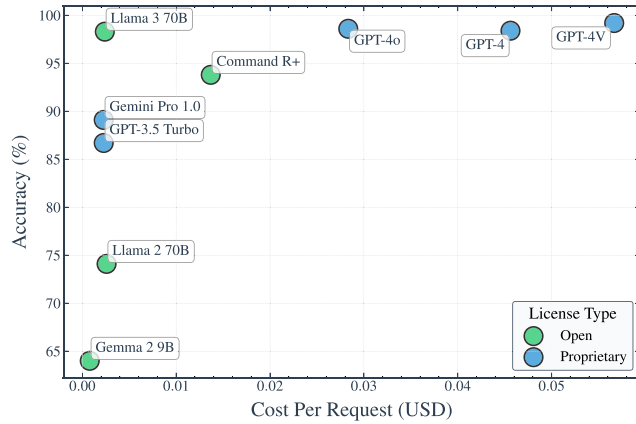


FIGURE 6. Accuracy vs. estimated cost per request for LLMs.

4 for GPT-4V, Gemini Pro 1.0 Vision, GPT-4, GPT-3.5, Llama2, and Gemini Pro 1.0. The detection accuracy based on the threshold setting for *phishing_score* also demonstrated the superior performance of GPT-4V compared to other models.

C. COST-PERFORMANCE ANALYSIS

In this section, we analyze the API costs incurred during the evaluation experiments using LLMs, as well as the cost and performance when using the latest models.

1) FINANCIAL COST CONSUMED IN THE EXPERIMENT

In our evaluation experiment using the ChatGPT API for our dataset of 2,000 websites, the total costs for GPT-4V, GPT-4, and GPT-3.5 were \$358.65, \$304.26, and \$16.30, respectively. As a result, the average cost per website was \$0.179 (GPT-4V), \$0.152 (GPT-4), and \$0.008 (GPT-3.5). Note that these figures are based on the pricing of the model versions as of March 2023.

2) PERFORMANCE AND COST COMPARISON OF LATEST MODELS

We conducted a performance and cost comparison using the latest models and pricing as of July 2024. In addition to the evaluation experiments described above, we conducted further tests on GPT-4o, in vision mode, as well as the open-source models—Command R+, Llama 3 70B, and Gemma 2 9B—in normal mode. We used the same dataset as in the evaluation experiments, comparing a total of nine models in terms of performance and cost. The cost calculation assumed maximum token consumption as described in Section III-B: 3,662 input tokens and 300 output tokens. The estimated cost per request (C_r) for a specific model m was calculated using the following equation:

$$C_r(m) = (T_i \cdot C_i(m)) + (T_o \cdot C_o(m)) \quad (4)$$

where T_i is the number of input tokens (3,662), $C_i(m)$ is the cost per million input tokens for model m , T_o is the number of output tokens (300), and $C_o(m)$ is the cost per million output

tokens for model m . For GPT-4V and GPT-4o operating in vision mode, additional tokens corresponding to the input image are included in the input token count. The screenshot images in our dataset, measuring 1065×1500 pixels, contribute an additional 1,105 tokens to the input. Table 3 summarizes the pricing and costs for each model. We based our calculations on official API prices where available. For open-source models without provider-specific APIs, we adopted Groq's [55] pricing for Llama 2, Llama 3, and Gemma 2, which offer the most cost-effective rates. Figure 6 displays the measured accuracy values for these models and the estimated cost per request. Notably, Llama 3 70B, an open-source model, achieved an accuracy of 98.3%, comparable to GPT-4 and showing significant improvement over Llama 2 70B. Its ability to run on closed servers or local devices, coupled with affordable API service options, makes it highly practical. GPT-4o demonstrated excellent cost-effectiveness, substantially reducing costs compared to GPT-4V while maintaining equivalent performance with an accuracy of 98.6%.

These results are significant in the current state of phishing countermeasures, which often involve extensive manual efforts by community-based platforms (e.g., PhishTank), security vendors, and law enforcement. Our system accurately identifies phishing sites rapidly and cost-effectively, generating detailed reports in multiple languages, potentially surpassing human experts. From the perspective of end-users, Llama 3 70B, with its cost of \$0.002 per web page for inspection, is approaching a practical level for real-time examination of accessed websites through browser extensions or standalone applications. The lightweight model Gemma 2 9B did not match the performance of models with higher parameter counts. This discrepancy likely stems from their limited ability to interpret long-context prompts. However, Gemma 2 9B recorded a True Positive Rate of 86.5% and can operate swiftly on personal devices such as laptops. This suggests the potential for future local execution of ChatPhishDetector on individual devices using lightweight LLMs. Given the current competition in LLM development, with proposals for open source models with improved performance and proprietary models with lower API usage fees, our system is likely to become more cost-effective and accessible to individual users in the near future.

D. ANALYSIS OF LLM OUTPUT CONSISTENCY

In the experiments conducted thus far, we executed each LLM using default parameters. In this section, we analyze the consistency of LLM responses by varying the Temperature parameter. Lower Temperature settings (with 0 being the minimum) result in the selection of responses with the highest probability, leading to more deterministic outputs. We set the Temperature of GPT-4o to 0 and analyzed the same dataset. The results yielded a precision of 97.2%, recall of 99.3%, and accuracy of 98.2%. While slightly lower than the 98.6% accuracy reported in Section V-C2,

TABLE 3. Performance and cost comparison of LLMs.

Model	Accuracy	Input Cost (per 1M tokens)	Output Cost (per 1M tokens)	Estimated Cost Per Request	Model License
GPT-4V	99.2%	\$10.00	\$30.00	\$0.057	Proprietary
GPT-4o	98.6%	\$5.00	\$15.00	\$0.028	Proprietary
GPT-4	98.4%	\$10.00	\$30.00	\$0.046	Proprietary
Llama 3 70B	98.3%	\$0.59	\$0.79	\$0.002	Open
Command R+	93.8%	\$3.00	\$9.00	\$0.014	Open
Gemini Pro 1.0	89.1%	\$0.50	\$1.50	\$0.002	Proprietary
GPT-3.5 Turbo	86.7%	\$0.50	\$1.50	\$0.002	Proprietary
Llama 2 70B	74.1%	\$0.64	\$0.80	\$0.003	Open
Gemma 2 9B	64.0%	\$0.20	\$0.20	\$0.001	Open

TABLE 4. Performance comparison by language.

Model	Language	Precision	Recall	Accuracy	F-measure
GPT-4V	English	98.5%	99.4%	99.1%	99.0%
GPT-4V	Non-English	98.9%	99.8%	99.2%	99.3%
GPT-4	English	98.2%	98.3%	98.4%	98.3%
GPT-4	Non-English	98.5%	98.5%	98.3%	98.5%
GPT-3.5	English	98.5%	85.5%	92.8%	91.5%
GPT-3.5	Non-English	97.3%	88.2%	91.9%	92.5%

these results are comparable. This suggests that Temperature may not significantly impact system accuracy. It implies that system tuning is possible: increasing Temperature when diversity is prioritized, or decreasing it for more deterministic responses. Further investigation is needed from multiple perspectives, including model stability, adaptability to diverse environments, and responsiveness to the latest attack methodologies.

E. COMPARATIVE ANALYSIS OF ENGLISH AND NON-ENGLISH SITES

We analyzed the performance of phishing detection by separating the results into English and non-English categories. As described in Section IV, our dataset comprises 656 English and 344 non-English phishing sites, along with 536 English and 464 non-English non-phishing sites. Building on the experimental results presented in Section V-B, we further analyzed the performance metrics for each language category. Table 4 shows the detection results for English and non-English websites using GPT-4V, GPT-4, and GPT-3.5 models.

The results indicated minimal differences in performance metrics between English and non-English websites. The differences in accuracy between English and non-English datasets are 0.1% for GPT-4V, 0.1% for GPT-4, and 0.9% for GPT-3.5. These results suggest that more advanced models such as GPT-4V and GPT-4 have smaller discrepancies in detection accuracy across languages compared to GPT-3.5. This finding is consistent with our expectations of more powerful models having more consistent accuracy across languages. Our analysis showed that advanced models can accurately detect phishing sites regardless of language.

F. EXAMPLES OF LLM RESPONSES

In this section, we describe specific examples of responses when LLMs correctly detect phishing sites.

Response 1 - GPT-4

```
1. Suspicious elements:
- The URL contains a subdomain
"securitypages", which is unrelated
to the legitimate Facebook domain
(www.facebook[.]com).
- The extracted text alerts the user
about having 12 hours to cancel the
account. This is a social engineering
technique often used in phishing
attacks.
- Furthermore, the link
provided redirects to a
suspicious, non-legitimate URL:

"http://centrenotificationvices.duckdns
[.]org/cntre.html".
2. The brand name identified is Meta
Facebook.
3. The site appears to be a phishing
site because of the suspicious URL and
social engineering tactics in the text.
4. JSON-formatted output:
'''
{
  "phishing_score": 9,
  "brands": "Meta Facebook",
  "phishing": true,
  "suspicious_domain": true
}
'''
```

1) PHISHING EXAMPLE A

Figure 7 shows a screenshot image of a phishing site (securitypages.start[.]page), and Response 1 represents the response generated by GPT-4. We have defanged some of the URLs included in the response. This website impersonates Facebook and attempts to create a sense of urgency regarding account issues for the user. GPT-4 correctly identified this website as being associated with the “Meta Facebook” brand and determined that the domain name was not legitimate Facebook. Furthermore,

GPT-4 recognized the presence of SE techniques and highlights the existence of suspicious links within the HTML. Based on these observations, GPT-4 set the *phishing_score* to 9, marking both *phishing* and *suspicious_domain* as true.

Response 2 - GPT-4V

1. Analyze the HTML, URL, and screenshot image:
 - URL: The domain name in the URL is "jogeshchaudhuricollege[.]org" which does not match any known Amazon domain, a known brand, and does not seem relevant to an Amazon sign-in page. Also, the URL contains a suspiciously long and complex query string.
 - HTML: The presented HTML attempts to replicate the Amazon sign-in page, including the Amazon logo and branding. However, the action attribute of the form element points to "check_login.php", which is not typically how Amazon's legitimate login processes work.
 - Image: The screenshot image resembles an Amazon sign-in page, which is a typical tactic used in phishing attempts to gain the trust of the user. The layout and design are very similar to the authentic Amazon site.
2. Identify the brand name:
 - The HTML and image suggest that the site is imitating the Amazon sign-in page.
3. Conclusion:
 - The site appears to be a phishing site. The URL does not correspond with the legitimate Amazon domain, and the HTML and image are mimicking an Amazon sign-in page to trick users into providing their credentials.
4. JSON-formatted output:

```
```json
{
 "phishing_score": 9,
 "brands": "Amazon",
 "phishing": true,
 "suspicious_domain": true
}
```
```

2) PHISHING EXAMPLE B

Figure 8 shows a phishing site impersonating the Amazon login page. In Response 2, which is the result generated by GPT-4V, the brand "Amazon" was identified in both the HTML and screenshot. GPT-4V found suspicious elements in the HTML related to the login process and recognized visual similarities with the legitimate Amazon website. GPT-4V successfully identified this phishing site based on several factors, including the suspiciousness of the URL query string and inconsistencies with the legitimate domain name.

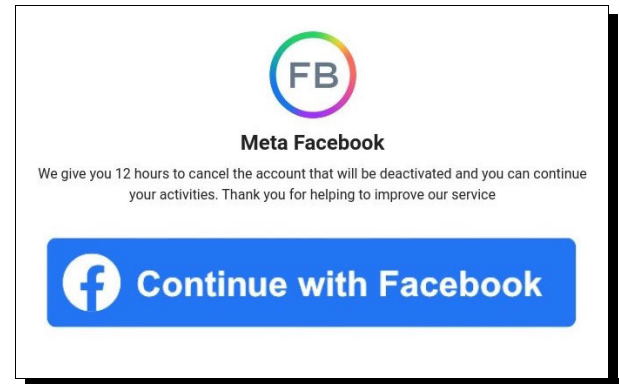


FIGURE 7. Phishing Example A: Facebook phishing site.

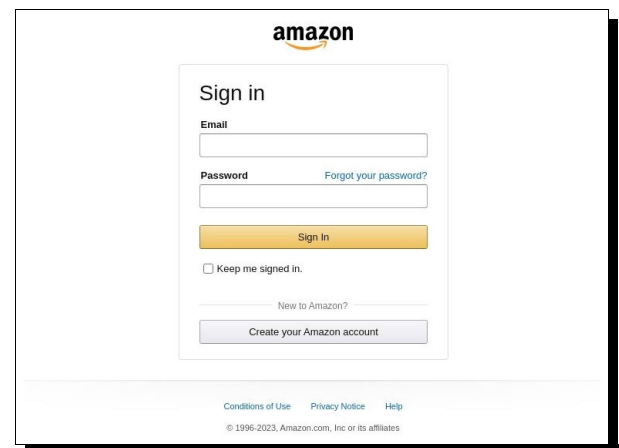


FIGURE 8. Phishing Example B: Amazon phishing site.

G. EVIDENCE FOR IDENTIFYING PHISHING SITES

In the analysis of phishing sites using LLMs, an important question arises: what evidence do LLMs rely on to accurately identify phishing sites? This section examines seven specific types of evidence used to detect phishing sites. These types of evidence were particularly effective for the GPT-4 and GPT-4V models, which produced the most accurate results.

1) LEGITIMACY OF DOMAIN NAMES

The most crucial evidence for identifying phishing sites is when the inspected website impersonates a legitimate brand but its domain name does not match the official domain name. Our prompt instructs LLMs to extract the brand name from the HTML, screenshot image, or OCR-extracted text and match it with the legitimate domain name. This process involves more than simple named entity recognition; it relies on advanced analytics to determine and extract the most appropriate brand name from all the information on the website. In addition, in vision mode, LLMs can accurately extract brands based on known brand logos, text strings within images, and the overall appearance of the website. Since LLMs have already been trained on various brands and their corresponding domain names, they can accurately detect inconsistencies between the extracted brand and its official domain name. LLMs can also identify if the domain name included in the provided URL is a fake domain name (domain

squatting [31], [53]) attempting to deceive users. For example, they correctly recognized that `disc0rd[.]pro`, which displayed a download page for Discord's installer, was not the legitimate domain name `discord[.]com`. Also, GPT-4V explained `www.na-amazon-creturns[.]com` as *The URL contains "amazon" but with added dashes and extra characters that are not typical of legitimate Amazon URLs.*

2) FAKE SECURITY WARNING

LLMs are also effective in detecting fake security alerts such as malware infection, a common SE technique on the web. This extends beyond the simple detection of whether an infection warning is being displayed. It enables the assessment of authenticity by examining suspicious grammar, unnatural language usage, and overstated warnings as indicators of potential deception. For instance, the website `landiingpages[.]beauty`, which displayed a screen resembling Microsoft Windows Defender's virus scan, was analyzed to display fake security warnings such as *このPCへのアクセスはセキュリティ上の理由でブロックされています(Access to this PC is blocked for security reasons)* and *脅威を発見 (Threat found) - Trojan Spyware App: Ads.financetrack(1).exe*. Furthermore, the website `plfkuwyacu.duckdns[.]org`, which displayed the logo of mobile carrier SoftBank, was recognized for a series of social engineering tactics. GPT-4 accurately analyzed the psychological manipulation employed, which involves urging users to install *SoftBank セキュリティ無料版アプリ (SoftBank Security App Free Edition)*, after they encounter a fake infection warning on this website that displays *マルウェアが検出されました (Malware detected)*.

3) FAKE ACCOUNT ISSUE

Phishing sites often display warnings claiming that there are issues with the user's account, aiming to steal their login credentials. An example of this is the website `m4agence.web[.]app`, which was analyzed as a phishing site targeting the bank Société Générale. GPT-4 identified that it employed a SE technique as follows: *The text extracted using OCR alerts the user to a problem with their account, which can be a typical technique of phishing attacks*. Furthermore, it explained the presence of suspicious HTML elements on this website as follows: *The HTML contains a link to a different domain than the one specified in the visible text: "https://dev-sgwebnetauth.pantheonsite[.]io/wp-content/sysconnect" instead of "www.societegenerale[.]fr/synchronisation-agence."* LLMs have a high capability for HTML analysis, such as detecting inconsistencies between the text of the `a` element and the link specified in the `href`.

4) URGENT PAYMENT REQUEST

Phishing sites that impersonate courier services and generate alerts about package issues, while creating a sense of urgency for payment, are targeting brands worldwide. An example is

`royalmail-online[.]com`, which disguised as Royal Mail and requested additional payment due to the overweight of the shipment. LLMs identified this as a phishing site based on the mismatch in the domain name and the presence of phrases such as *Interrupted delivery* and *Additional charges of 0.76£*, indicating the employment of SE techniques. In the case of a phishing site (`www.caaarem[.]mx`) impersonating UPS, the LLMs detected the suspicious phrase *790,45 HUF fizetése: Szállítási költség (Pay 790,45 HUF: Shipping cost)*. Additionally, GPT-4 provided an explanation stating, *The request for the user's credit card information, including card number, expiration date, and security code*. This detailed analysis demonstrates GPT-4's ability to examine HTML elements and understand how they are designed to encourage user input. Moreover, `tlmcjohsvz.duckdns[.]org` was identified as a phishing site demanding payment for outstanding tax obligations. GPT-4 provided the following statement as evidence: *The HTML contains alerting text that seems like a phishing attempt, such as "差押最終通知" (Final Attachment Notice), informing the user about an unpaid tax and urging them to pay using specific methods.*

5) FAKE LOGIN ERROR

As demonstrated in Section V-F, some phishing sites display misleading error messages, such as indicating that the login credentials are wrong or alerting users that their credit card number is invalid, even when no input has been provided. These SE techniques aim to deceive users and extract sensitive information. For example, the website `www.interceptionbookingconfirmation[.]com`, pretending to be Booking.com, prompted users to input their credit card information, accompanied by an alert stating, *Your credit card was marked as invalid*. GPT-4V explained as follows: *The HTML contains a message designed to create a sense of urgency, informing the user that their credit card has been marked as invalid and requesting an update within 24 hours*. Similarly, the website `mail.sikkimrajshree[.]in` was identified as impersonating the logistics company SF Express. GPT-4 categorized it as a phishing site based on the displayed text, providing the following statement as evidence: *The HTML content contains an error message "无效的用名或密" which translates to "Invalid username or password", indicating that the user's account might have a problem, which can be a social engineering technique used in phishing attacks.*

6) FAKE REWARD

Phishing sites often employ deceptive tactics to capture users' interest. One common initial step is to offer fake rewards, such as monetary prizes, cryptocurrencies, gift cards, or smartphones. For instance, the website `www.mobilegoodies4you[.]com` impersonates SFR, a telecommunication company, and displayed a fraudulent cash prize. GPT-4 identified the phrase *Votre adresse IP a été tirée au sort et vous avez une chance de gagner un 460,00 € en espèces! (Your IP address has been entered into*

a draw for a chance to win €460.00 in cash!) within the website as an example of an unexpected reward. Similarly, the phishing site `allesettlemenie[.]top`, which impersonates the e-commerce brand Allegro. This site was identified as using SE techniques to attract users' interest such as *Sign up or log in today to shop and earn cash! Withdrawal to bank account (limited to one mobile number)*. In the case of a phishing site `me7q1.vettedeb[.]xyz` targeting Sberbank, users are prompted to participate in a survey in exchange for cash. GPT-4 recognized the use of a cash reward to attract users' interest, as indicated by the statement: *The text contains social engineering techniques such as enticing users with rewards ('ПОЛУЧИТЬ ВОЗНАГРАЖДЕНИЕ ДО 600 000 РУБ')*, which means "get reward up to 600,000 RUB."

7) AUTHENTICATION REQUEST

Phishing sites target not only users' login credentials but also their Two-Factor Authentication (2FA) information. For instance, the website `demo.crustncakes[.]com` impersonates the payment service BenefitPay and deceived users into inputting an SMS code for the purpose of verifying a transaction. GPT-4V explained that this technique as follows: *The HTML contains social engineering techniques such as alerting the user to a problem with an expired SMS code and prompting for immediate action, which is a tactic often used by phishing attacks to create a sense of urgency.*

H. FALSE DETECTION IN GPT-4

To assess the performance limitations of the proposed system and to gain insights for potential improvements, we analyzed the false positives and false negatives generated by GPT-4, which outperformed other models in normal mode. In the subsequent sections, we use GPT-4 as a benchmark for comparison against other models.

1) FALSE POSITIVES (GPT-4)

To explore the causes of false positives in LLMs, we analyzed 17 false positives for GPT-4 by classifying them into six factors based on the responses generated by the model.

a: MISIDENTIFYING SE TECHNIQUES

As discussed in Section V-G, GPT-4 demonstrated precise identification of various SE techniques commonly used in phishing sites. However, it falsely flagged some non-phishing sites as phishing. In our experiment, GPT-4 misidentified `cfspart.impots.gouv[.]fr` as containing SE techniques in an HTML element. This element, initially hidden using the `display:none` property, triggers an alert message upon receiving incorrect input in the form. GPT-4 correctly recognized `impots.gouv[.]fr` as a legitimate domain name. However, it misidentified this website as a distinct domain name due to the presence of the subdomain "cfspart". This suggests a potential misunderstanding of domain name structures by GPT-4. Although there were

other cases where GPT-4 reported that some legitimate sites contained elements using SE techniques, they were all classified as non-phishing because GPT-4 correctly verified that they matched legitimate domain names.

b: MULTIPLE DOMAIN NAMES OF LEGITIMATE BRANDS

GPT-4 sometimes misclassified legitimate brands that operate multiple domains as phishing sites. This occurred when GPT-4 could identify one or several of these domain names but did not have the knowledge of the specific domain name it was checking. Regarding this factor, GPT-4 produced four false positives for the following domain names: `textttm.botw[.]com` (another domain name for `bankofthewest[.]com`), `aplusfcu.balancepro[.]org` (`aplusfcu[.]org`), `hb.redlink.com[.]ar` (`bancodelapampa.com[.]ar`), and `cloudflare[.]net` (`cloudflare[.]com`). Additionally, it falsely flagged the law firm Pinsent Masons' website `www.aboutcookies[.]org` as phishing. This false positive occurred because the extracted brand name Pinsent Masons was not present in the domain name.

c: GLOBAL BRANDS WITH LOCAL DOMAIN NAMES

False positives can occur when global brands use local domain names specific to different countries. GPT-4 produced false positives for three domain names due to their mismatch with the most recognized legitimate domain names: `www.aliexpress[.]us` (the most recognized domain name by GPT-4: `www.aliexpress[.]com`), `sube.garantibbva.com[.]tr` (`garantibbva[.]com`), and `www.sicredi.com[.]br` (`www.sicredi[.]com`).

d: NUMEROUS SUBDOMAINS

GPT-4 sometimes failed to identify a legitimate domain name if it had multiple subdomains, even if the domain name was under a legitimate domain name known to GPT-4. The following domain names were false positives in this category: `cloud.walletconnect[.]com`, `entry11.bk.mufg[.]jp`, and `www.my.commbank.com[.]au`.

e: NON-ENGLISH WEBSITES

While GPT-4 demonstrated high accuracy in identifying SE techniques across a wide range of languages, false positives can occur due to insufficient knowledge of non-English websites. The following two domain names were falsely flagged as phishing sites as they were not well-known: `justhost[.]ru` and `www.jb51[.]net`.

f: LONG URL QUERY STRING

GPT-4 correctly recognized the domain name `auth.talktalk.co[.]uk` as legitimate and did not detect any SE techniques within the web page content. However, it falsely flagged this site as phishing due to an extremely long URL query string (360 characters) in the URL path.

LLMs are known to improve their performance through Retrieval Augmented Generation (RAG), which involves referencing external data. In this study, we employed LLMs solely as classifiers for identifying phishing sites. To further reduce false positives, this could be achieved by creating URL allow lists and utilizing them as external data references. Additionally, this has the potential to effectively identify phishing sites by detecting discrepancies between these sites and legitimate domain names, thereby also contributing to the reduction of false negatives. The human-in-the-loop approach adopted by Zheng and Becker [56] in their proposed email security tool suggests a potential improvement to our system's implementation of RAG. Their use of qualitative methods and iterative user feedback could be adapted to enhance the effectiveness of our RAG integration. Furthermore, applying the concept of hybrid RAG, which combines Sentence-Window and Parent-Child techniques as proposed by Omrani et al. [57], could potentially improve the search accuracy for phishing site-related information. Incorporating a re-ranking mechanism may also enhance the relevance and contextual coherence of retrieved information, leading to more accurate phishing detection.

2) FALSE NEGATIVES (GPT-4)

GPT-4 demonstrated an improvement in reducing false negatives compared to GPT-3.5, achieving an 11.7% reduction. However, there are cases where GPT-4 erroneously classifies certain phishing sites as non-phishing (16 cases), necessitating a thorough analysis of the underlying causes. Out of the 16 FNs, except for 2 cases, GPT-4 correctly identified the brand names of the remaining websites. Among these FNs, 8 websites lacked any descriptive text other than JSON-formatted content in their responses, making it impossible to analyze the basis of their classification. There were 4 FNs where GPT-3.5 correctly identified the phishing sites, but GPT-4 did not.

a: FALSELY IDENTIFIED DOMAIN NAMES AS LEGITIMATE

Despite correctly identifying the targeted brand names for the following 5 phishing sites, GPT-4 erroneously classified the domain names as legitimate. For instance, GPT-4 misclassified the phishing site `www.phototan-push[.]de` (disguised as `commerzbank[.]com`) by stating *there's no suspicion surrounding the domain name*, thus incorrectly labeling it as a non-phishing site. The phishing site `www.gmenduroracingteam[.]it` was identified as non-phishing by GPT-4, because the legitimate URL of the brand (`https://www.mooney[.]it/`) that this phishing site deceived was included as a link in the HTML, even though the actual domain name is different. The following three sites were identified as false negatives by GPT-4, but correctly identified by GPT-3.5. A website impersonating `www.gov[.]uk` (`claim.redundancy-payments.org[.]uk`) was classified as phishing by GPT-3.5 due to its SE technique

of requesting the national insurance numbers and bank details. In contrast, GPT-4 accurately identified the brand as "GOV.UK" but indicated *it is likely that the site is a legitimate one*. GPT-4 also suggested *it is always better to verify the authenticity of the URL by visiting the official government website*. `etmmetaverse[.]com`, a phishing site for Office 365, was correctly classified as phishing by GPT-3.5 based on the mismatch in the domain name and links to other pages. However, GPT-4 offered a neutral explanation, stating *there is not enough evidence supporting that this is a phishing site*, despite assigning a *phishing_score* of 5 and labeling both *phishing* and *suspicious_domain* as *unknown*. Furthermore, both GPT-3.5 and GPT-4 correctly identified the brand SI-DEP (France's national Covid-19 screening system) for the phishing site `ca8567c7fa0141658f08b0dabe13d5ee.v1.radwarecloud[.]net`. While GPT-3.5 correctly pointed out *The domain name "radwarecloud.net" does not appear to be associated with the brand name "SI-DEP"*, GPT-4 failed to detect the phishing attempt in this case..

b: FAILURE TO IDENTIFY DOMAIN SQUATTING

The website `www.americanexpressseguros[.]com` was a phishing site for American Express, offering insurance solicitations. Despite containing the phrase *Recibe hasta \$2,000.00 M.N de bonificación al contratar (Receive up to \$2,000.00 M.N of bonus when contracting)*, GPT-4 failed to recognize the SE technique employed. Although it was a case of domain squatting, GPT-4 incorrectly identified it as a legitimate domain.

c: FAILURE TO IDENTIFY SE TECHNIQUES

The phishing site `phpstack-197144-1061735.cloudwaysapps[.]com` presented an insurance survey, without specifically targeting any particular brand. Since the site lacks prominent elements such as rewards or a sense of urgency, it was mistakenly classified as a legitimate site. Similarly, the e-commerce site `lojanewgeneration[.]com` attempted to attract users with the phrase *daily offers*, yet GPT-4 failed to identify the SE technique employed, leading to its classification as a legitimate site.

I. COMPARATIVE ANALYSIS: GPT-4 VS GPT-4V

This section provides an in-depth comparison of the performance differences between GPT-4 and GPT-4V, both of which have high phishing detection capabilities in normal and vision modes. GPT-4V effectively reduced both false positives (from 17 to 13) and false negatives (from 16 to 4) when compared to GPT-4. A notable strength of GPT-4V is its ability to identify various SE techniques used to deceive users. This capability is based on visual information, including logos and page layouts in screenshot images, in addition to the advanced context interpretation abilities found in GPT-4. GPT-4V can accurately analyze the legitimacy of content by assessing factors such as brand recognition from logo images

and the similarity of page appearances to legitimate sites. In its brand identification, GPT-4V identified logo images in 242 phishing sites and used them as one of the classification clues. As examples of cases where GPT-4V correctly identified phishing sites and GPT-4 failed, GPT-4V noted that for `www.phototan-push[.]de`, *The design of the page closely mimics that of the legitimate Commerzbank login page*. Also, GPT-4V identified a phishing site at `www.gmenduroracingteam[.]it` (FN of GPT-4) by recognizing the brand logo of Mooney (a payment service) and detecting inconsistencies in the domain name. Additionally, for `claim.redundancy-payments.org[.]uk`, GPT-4V analyzed the screenshot image and correctly identified it as phishing, stating that *The GOV.UK logo and design are used*. In the following, we analyzed the false positives and false negatives of GPT-4V.

1) FALSE POSITIVES (GPT-4V)

GPT-4V had 13 false positives, with 3 cases remaining unexplained due to the lack of descriptions other than JSON, and 2 cases were incorrectly detected for the same reasons as GPT-4. Notably, GPT-4V correctly identified 15 out of 17 false positives from GPT-4 as non-phishing. GPT-4V incorrectly identified `country.db[.]com` as a phishing site, primarily because of an unfamiliar subdomain. However, the website received a low *phishing_score* of 3, mainly due to insufficient clear evidence supporting the phishing classification. The website `www.kinopoisk[.]ru` was also incorrectly detected due to the presence of a CAPTCHA in a screenshot. The website `ib.bri.co[.]id` was misclassified as phishing because GPT-4V interpreted a request to download a mobile app in the screenshot as a malware download attempt. The Trade Desk's "Control Over Your Personal Information" page (`adsrvr[.]org`), was incorrectly flagged as a phishing site due to its different domain name from the legitimate `thetradedesk[.]com`. The inclusion of subdomains led to the misclassification of `involta.service-now[.]com` and `kr.battle[.]net` as suspicious. Furthermore, `mega[.]io` was incorrectly identified as phishing. While GPT-4V recognized the cloud storage brand "Mega" from the website, it mistakenly considered the correct domain name to be `mega[.]nz`. Similarly, `cloudflare[.]net` was incorrectly detected due to a different TLD from the recognized legitimate domain `cloudflare[.]com`.

2) FALSE NEGATIVES (GPT-4V)

GPT-4V had the lowest number of false negatives of any model with only 4 cases, two of which were also false negatives on GPT-4 for the same reason (`lojanewgeneration[.]com` and `www.americanexpresseguros[.]com`). GPT-4V successfully identified 14 out of 16 false negatives from GPT-4 as non-phishing. One of the remaining two FNs is the Safra Bank phishing site (`secure.safrabankoffshore[.]com`). GPT-4V explained that *the domain 'safrabankoffshore.com'*

may raise suspicion as it includes 'offshore,' which could be a tactic to give the false impression of a special or exclusive service. Furthermore, GPT-4V misidentified the login page of this site as legitimate through image analysis, leading to the false negative. GPT-4V recognized the GOV.UK brand from the phishing site `bankruptcy-form-fn-prod-ods.insolvency-development.co[.]uk`, however, GPT-4V was unable to determine that the domain name was not legitimate.

J. COMPARATIVE ANALYSIS: GPT-4 VS GPT-3.5

To analyze the impact of differences in model performance on phishing site detection, we conducted a comparative analysis between two models in normal mode, GPT-4 and GPT-3.5. Specifically, we thoroughly examined phishing sites that were successfully detected by GPT-4 but not by GPT-3.5. This allows us to uncover the reasons why LLMs are successful in detecting phishing sites. Of the 133 FNs of GPT-3.5, GPT-4 correctly identified 121 phishing sites. Upon analyzing these 121 phishing sites, we discovered three abilities in which GPT-4 exhibited superior performance compared to GPT-3.5:

- Determine the suspiciousness of domain names.
- Identify SE techniques.
- Detect phishing sites comprehensively by using multiple factors.

1) ABILITY TO DETERMINE THE SUSPICIOUSNESS OF DOMAIN NAMES

GPT-4 and GPT-3.5 differed in their ability to assess the legitimacy of domain names, especially to determine whether a domain name matches a legitimate domain name or exhibits suspicious characteristics. For instance, when analyzing the OpenAI phishing site `openai-gpt-4[.]com`, GPT-3.5 classified it as non-phishing due to the presence of the term "openai." In contrast, GPT-4 correctly identified it as phishing since it differed from the actual domain name, which is `openai[.]com`. In the case of a phishing site (`krakken-logi.mystrikingly[.]com`) impersonating the cryptocurrency exchange Kraken, both GPT-4 and GPT-3.5 successfully recognized the brand name. While GPT-4 identified the misspelling of "krakken-logi" as suspicious, GPT-3.5 classified it erroneously as a legitimate domain name based on the presence of "krakken". Furthermore, both GPT-4 and GPT-3.5 accurately identified the phishing site `firstcitizncb[.]com` as distinct from the legitimate domain name `firstcitizens[.]com`. However, GPT-3.5 considered it to be a variation of the legitimate domain name and not a phishing site. Another example is the phishing site `correos-es.firebaseioapp[.]com`, which impersonates Spain's national postal service, Correos. While GPT-3.5 classified it as a legitimate domain name, GPT-4 correctly recognized it as a suspicious domain due to its hosting on Google Firebase.

2) ABILITY TO IDENTIFY SE TECHNIQUES

GPT-4 successfully identified SE techniques that were missed by GPT-3.5 in some phishing sites. For example, in the case of `verify.vodafone-uk[.]com`, which GPT-3.5 explained that *The page warns users about the potential termination of their phone number*. However, GPT-4 recognized the presence of SE techniques by explaining that the websites warned users about the potential termination of their phone number. Additionally, GPT-4 noted that *The domain name in the URL is “verify.vodafone-uk.com”, which seems odd with the hyphen between “vodafone” and “uk”*. In the phishing site (`aktivere-bnkid.web[.]app`) impersonating the Swedish identification system BankID, GPT-4 identified the SE technique by highlighting that it requested personal information such as the user’s personal number, phone number, and user-ID. In contrast, GPT-3.5 incorrectly stated that the website *does not contain any obvious social engineering techniques*.

3) ABILITY TO DETECT PHISHING SITES COMPREHENSIVELY BY USING MULTIPLE FACTORS

In some cases, LLMs may mistakenly identify suspicious elements on legitimate sites. For example, they identified legitimate error messages (e.g., “wrong password”) displayed after submitting a form as an indication of social engineering. LLMs also found the inclusion of the year 2023 in the copyright notice to be suspect because of the future year. This is due to a lack of knowledge regarding the current year. However, GPT-4 tends to make overall accurate determinations by prioritizing more reliable information, although it occasionally provides incorrect evidence. On the other hand, GPT-3.5 may classify a phishing site as benign even though it identifies the correct pieces of evidence. The following are examples of sites that GPT-3.5 incorrectly identified as non-phishing but GPT-4 correctly detected as phishing. The website `b2meguy[.]com` displayed an attention-grabbing statement at the top of the website: *Obtenga acceso instantáneo al software de Quantum AI, y gane de 3200€ al día!* (Get instant access to Quantum AI’s software, and earn from 3200€ per day!). Both GPT-4 and GPT-3.5 identified this statement as suspicious. However, while GPT-3.5 did not classify it as a phishing site, GPT-4 correctly identified it as phishing based on the explanation that *it presents unrealistic promises of gains*. Another example is the phishing site `verification-appeal-code.firebaseio[.]com`, which pretended to be Facebook and asked users to respond to claims of intellectual property infringement. Both GPT-4 and GPT-3.5 detected the request for sensitive information from visitors, however, only GPT-4 flagged it as a phishing site based on the suspiciousness of the domain name.

VI. DISCUSSION

In this section, we discuss the limitations of our system, as well as its capabilities and potential deployment scenarios.

A. LIMITATIONS

LLMs provide flexible and varied responses because their output is determined probabilistically. However, this also means that detection results can change depending on the experiment. In this study, we used default values for LLMs’ parameters such as `top_p` and temperature. In order to obtain reliable results for classification, adjustments for specific purposes may be required.

Methods that use LLMs, including our system, may be susceptible to prompt injection attacks [58], [59], where the original prompt is overwritten and malicious content is inserted into the response. Our system employs simple countermeasures by simplifying the HTML and clarifying text sections through the placement of triple backticks. However, phishing sites may use prompt injections in the future to avoid analysis by LLMs. More advanced defenses against prompt injection attacks will be needed.

Since each LLM is trained on data up to a specific time period (e.g., the ChatGPT models used in this study were trained on data through September 2021), it may not be able to accurately classify phishing and non-phishing sites associated with services created after that date. The classification ability could potentially be improved by externally referencing a list of domain names corresponding to brands or by using a fine-tuned LLM.

B. SYSTEM CAPABILITIES AND DEPLOYMENT SCENARIOS

Our proposed system leverages the analytical capabilities and inherent knowledge of LLMs without requiring human-annotated training data, unlike traditional machine learning approaches. A key benefit of this system is its ability to automatically assess potential phishing sites without human intervention, while also generating comprehensive reports that allow for subsequent human review if required. This dual functionality both reduces the initial need for manual analysis and provides a basis for further human review, improving the overall efficiency and accuracy of phishing detection processes. In terms of concrete deployment scenarios, security vendors and law enforcement agencies can use this system to enhance their phishing threat intelligence. It enables automated analysis of reported suspicious sites to determine whether they are likely phishing attempts, without the need for human resources. The system can be used to analyze URLs and domain names extracted from social media [45], as well as potentially malicious domain names identified through certificate transparency (CT) logs and passive DNS data [54]. As discussed in Section V-C2, many legal investigations and creation processes of threat intelligence still rely heavily on manual inspection. Our system proves to be cost-effective in reducing this workload. Looking ahead, we can envision a future where our proposed system is integrated into personal devices or cloud-based inspection services, enabling near real-time phishing site detection for accessed web pages. However, given the current state of LLM technology, the high-performance models

TABLE 5. Brands targeted by phishing sites.

| | | |
|---------------------------|--|------------------------------|
| A+ Federal Credit Union | AEON CARD | Alpha Web |
| Amazon | American Express | Apple |
| Ardoiz | BECU Online Banking | BNL |
| BRImo | Banca Sella | Banco Desio |
| Banco La Pampa | Bancoagrícola | Bancolombia |
| Bank of America | Barclays | Battle.net |
| Bendigo Bank | Bradesco | CAJA |
| CIMB Ni | Chunghwa Post Co. | Citizens Bank |
| CodeSquare | Coin Wallet | Colissimo |
| Commonwealth Bank | Correos | Credomatic |
| Crypto.com | DHL | DKB |
| Deutsche Bank | Deutsche Post DHL Group | Disney |
| Docomo | DocuSign | Dropbox |
| EATA | EClick PORTAL | ETC |
| EXPRESSPAY | Ebay | Emirates Post |
| Entrust | Facebook | Fifth Third Momentum Banking |
| First Citizens Bank | GLOBAL PASS | GO online |
| GOV.UK | Garanti BBVA | Garena |
| Gazprom | Gemini | GitLab |
| Google | Gruppo BNP Paribas | IBC |
| ING | ImToken | Impots.gouv.fr |
| Instagram | Involta | JUHACHI-SHINWA BANK |
| JUNO | Kakao | Kusainon |
| La Banque Postale | Livelo | METAMASK |
| MIR VISA | M&T Bank | Ma Banque |
| Mashreq Online Banking | MasterCard | Mercari |
| Microsoft | Minnesota Unemployment Insurance Benefits System | Mitsubishi UFJ Bank |
| Mitsui Sumitomo Card | Mygrow | NAB Internet Banking |
| NAVY FEDERAL Credit Union | NETFLIX | NLB Banka |
| Nexi | Nordea | ORLEN |
| OakPay | OneDrive | Orange |
| OurTime | Outlook.com | PNC Online Banking |
| PRESTÍA | PancakeSwap | PayPal |
| PayPay | Post canada | QUOTY |
| Qatar Post | RENNER | REVOLUT INTERNATIONAL BANK |
| Ronin Wallet | SAISONCARD | SBJ Bank |
| SDCCU | SFR | SMBC |
| SMBC Trust Bank | SPANKKI | STEAM |
| Santander | Satang | Schwab Safe |
| Scotiabank | Security Bank | SharePoint |
| Sicredi | Siemens | Slovenská POŠTA |
| Spotify | Swiss | Swiss Post |
| Swisscom | T-Mobile | TD Ameritrade |
| TESCO Bank | THEWEST | TalkTalk |
| Theta | Transcash | Trust Wallet |
| USAA | USPS Tracking | Ubisoft |
| UniCredit | Uphold | UPS |
| VALVE | VISA | Verizon |
| Vietcombank | WELLS FARGO | WalletConnect |
| WeTransfer | Weebly | Yahoo! |

require significant machine specifications and API costs to operate, making this usage scenario less feasible for all end users at present. Nevertheless, as shown in Section V, open-source models that can be deployed locally are already capable of detecting phishing sites with high accuracy. This suggests that if high performance models can be optimized to run faster on lower specification hardware, there would be significant benefits to users. The potential for more efficient, accessible phishing detection at the user level represents a promising direction for future research.

From a game theoretical perspective, as highlighted in recent research [60], [61], LLM-based countermeasures like ChatPhishDetector could significantly alter the dynamics between phishing attackers and defenders. This

scenario represents a dynamic game where both sides adapt their strategies continuously. While attackers may develop LLM-powered phishing content in response to sophisticated detection systems, the advanced language understanding and contextual awareness of LLMs give defenders a substantial advantage. LLMs can quickly detect and adapt to changing attack patterns, particularly identifying psychologically persuasive content aimed at increasing success rates. This capability could enhance the overall robustness of defense systems, potentially reducing long-term phishing success rates.

VII. CONCLUSION

In conclusion, this paper introduced a novel system called ChatPhishDetector for detecting phishing sites using

LLMs. Our system leverages a combination of web crawling techniques and contextual understanding of LLMs to automatically classify websites as phishing or not. Through an evaluation experiment, our system achieved remarkable performance, demonstrating the capabilities of LLMs to efficiently detect phishing sites by identifying brand impersonation and social engineering techniques. Comparative analysis with different modes, various models, and existing phishing detection systems revealed that our system, using GPT-4V, has superior detection ability. These findings suggest that LLMs can significantly contribute to automating the generation of threat intelligence, a task that typically requires substantial human resources. Furthermore, LLMs can support end-users in investigating suspicious websites, providing an additional layer of protection against phishing attacks. We provide the dataset and experimental results only upon request from researchers due to commercially licensed data inclusion and copyright issues.

APPENDIX PHISHING BRANDS

Table 5 is a list of 147 brands that were targeted by phishing sites in our dataset.

ACKNOWLEDGMENT

The authors would like to thank the use of large language models to generate example outputs of their proposed system in Sections V. This AI-generated content serves solely as demonstrative material, while all core research and analysis were conducted by the human authors. This disclosure complies with IEEE guidelines on AI-generated content in articles.

REFERENCES

- [1] A. Radford, K. Narasimhan, T. Salimans, and I. Sutskever. (2018). *Improving Language Understanding By Generative Pre-training*. [Online]. Available: <https://openai.com/index/language-unsupervised/>
- [2] T. B. Brown et al., "Language models are few-shot learners," 2020, *arXiv:2005.14165*.
- [3] L. Ouyang, J. Wu, X. Jiang, D. Almeida, C. L. Wainwright, P. Mishkin, C. Zhang, S. Agarwal, K. Slama, A. Ray, J. Schulman, J. Hilton, F. Kelton, L. Miller, M. Simens, A. Askell, P. F. Christiano, J. Leike, and R. Lowe, "Training language models to follow instructions with human feedback," in *Proc. NeurIPS*, 2022, pp. 27730–27744.
- [4] J. Achiam, S. Adler, S. Agarwal, L. Ahmad, I. Akkaya, F. L. Aleman, D. Almeida, J. Altenschmidt, S. Altman, S. Anadkat, and R. Avila, "GPT-4 technical report," 2023, *arXiv:2303.08774*.
- [5] (2024). *Introducing ChatGPT*. [Online]. Available: <https://openai.com/blog/chatgpt>
- [6] Z. Lin, J. Cui, X. Liao, and X. Wang, "Malla: Demystifying real-world large language model integrated malicious services," 2024, *arXiv:2401.03315*.
- [7] M. Gupta, C. Akiri, K. Aryal, E. Parker, and L. Praharaj, "From ChatGPT to ThreatGPT: Impact of generative AI in cybersecurity and privacy," *IEEE Access*, vol. 11, pp. 80218–80245, 2023.
- [8] O. Gadyatskaya and D. Papuc, "ChatGPT knows your attacks: Synthesizing attack trees using LLMs," in *Data Science and Artificial Intelligence*, C. Anutariya and M. M. Bonsangue, Eds., Singapore: Springer, 2023, pp. 245–260.
- [9] T. Naito, R. Watanabe, and T. Mitsunaga, "LLM-based attack scenarios generator with IT asset management and vulnerability information," in *Proc. 6th Int. Conf. Signal Process. Inf. Secur. (ICSPIS)*, Nov. 2023, pp. 99–103.
- [10] Z. Yang, J. Allen, M. Landen, R. Perdisci, and W. Lee, "Trident: Towards detecting and mitigating web-based social engineering attacks," in *Proc. 32nd USENIX Secur. Symp.*, 2023, pp. 1681–1698.
- [11] T. Nelms, R. Perdisci, M. Antonakakis, and M. Ahamad, "Towards measuring and mitigating social engineering software download attacks," in *Proc. 25th USENIX Security Symp.*, 2016, pp. 773–789.
- [12] P. Vadrevu and R. Perdisci, "What you see is NOT what you get: Discovering and tracking social engineering attack campaigns," in *Proc. Internet Meas. Conf.*, Oct. 2019, pp. 308–321.
- [13] S. Tang, X. Mi, Y. Li, X. Wang, and K. Chen, "Clues in tweets: Twitter-guided discovery and analysis of SMS spam," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, Los Angeles, CA, USA, H. Yin, A. Stavrou, C. Cremers, and E. Shi, Eds., Nov. 2022, pp. 2751–2764.
- [14] J. Szurdi, M. Luo, B. Kondracki, N. Nikiforakis, and N. Christin, "Where are you taking me? Understanding abusive traffic distribution systems," in *Proc. Web Conf.*, J. Leskovec, M. Grobelnik, M. Najork, J. Tang, and L. Zia, Eds., Ljubljana, Slovenia, Apr. 2021, pp. 3613–3624.
- [15] Y. Lin, R. Liu, D. M. Divakaran, J. Y. Ng, Q. Z. Chan, Y. Lu, Y. Si, F. Zhang, and J. S. Dong, "Phishpedia: A hybrid deep learning based approach to visually identify phishing webpages," in *Proc. 30th USENIX Secur. Symp.*, M. Bailey and R. Greenstadt, Eds., 2021, pp. 3793–3810.
- [16] R. Liu, Y. Lin, X. Yang, S. H. Ng, D. M. Divakaran, and J. S. Dong, "Inferring phishing intention via webpage appearance and dynamics: A deep vision based approach," in *Proc. 31st USENIX Secur. Symp.*, Boston, MA, USA, K. R. B. Butler and K. Thomas, Eds., 2022, pp. 1633–1650.
- [17] H. Bijmans, T. Booi, A. Schwedersky, A. Nedgabat, and R. van Wegberg, "Catching phishers by their bait: Investigating the Dutch phishing landscape through phishing kit detection," in *Proc. 30th USENIX Secur. Symp.*, M. Bailey and R. Greenstadt, Eds., Aug. 2021, pp. 3757–3774.
- [18] M. Bitaab, H. Cho, A. Oest, Z. Lyu, W. Wang, J. Abraham, R. Wang, T. Bao, Y. Shoshitaishvili, and A. Doupé, "Beyond phish: Toward detecting fraudulent e-commerce websites at scale," in *Proc. IEEE Symp. Secur. Privacy (SP)*, Los Alamitos, CA, USA, May 2023, pp. 2566–2583.
- [19] K. Thomas, F. Li, A. Zand, J. Barrett, J. Ranieri, L. Invernizzi, Y. Markov, O. Comanescu, V. Eranti, A. Moscicki, D. Margolis, V. Paxson, and E. Bursztein, "Data breaches, phishing, or malware: Understanding the risks of stolen credentials," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, Dallas, TX, USA, B. Thuraisingham, D. Evans, T. Malkin, and D. Xu, Eds., Oct. 2017, pp. 1421–1434.
- [20] T. Koide, D. Chiba, M. Akiyama, K. Yoshioka, and T. Matsumoto, "It never rains but it pours: Analyzing and detecting fake removal information advertisement sites," in *Proc. 17th Conf. Detection Intrusions Malware Vulnerability Assessment*, 2020, pp. 171–191.
- [21] N. Miramirkhani, O. Starov, and N. Nikiforakis, "Dial one for scam: A large-scale analysis of technical support scams," in *Proc. Netw. Distrib. Syst. Secur. Symp.*, 2017, pp. 1–15.
- [22] A. Kharraz, W. Robertson, and E. Kirda, "Surveyllance: Automatically detecting online survey scams," in *Proc. IEEE Symp. Secur. Privacy (SP)*, San Francisco, CA, USA, May 2018, pp. 70–86.
- [23] P. Yang, G. Zhao, and P. Zeng, "Phishing website detection based on multidimensional features driven by deep learning," *IEEE Access*, vol. 7, pp. 15196–15209, 2019.
- [24] J. Wei, X. Wang, D. Schuurmans, M. Bosma, B. Ichter, F. Xia, E. H. Chi, Q. V. Le, and D. Zhou, "Chain-of-thought prompting elicits reasoning in large language models," in *Proc. NeurIPS*, 2022, pp. 24824–24837.
- [25] T. Kojima, S. S. Gu, M. Reid, Y. Matsuo, and Y. Iwasawa, "Large language models are zero-shot reasoners," in *Proc. NeurIPS*, 2022, pp. 22199–22213.
- [26] OpenAI. (2024). *GPT-4V(ision) System Card*. [Online]. Available: https://cdn.openai.com/papers/GPTV_System_Card.pdf
- [27] S. Abdelnabi, K. Krombholz, and M. Fritz, "VisualPhishNet: Zero-day phishing website detection by visual similarity," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, J. Ligatti, X. Ou, J. Katz, and G. Vigna, Eds., Oct. 2020, pp. 1681–1698.
- [28] H. Zhang, G. Liu, T. W. S. Chow, and W. Liu, "Textual and visual content-based anti-phishing: A Bayesian approach," *IEEE Trans. Neural Netw.*, vol. 22, no. 10, pp. 1532–1546, Oct. 2011.
- [29] N. Nikiforakis, S. Van Acker, W. Meert, L. Desmet, F. Piessens, and W. Joosen, "Bitsquatting: Exploiting bit-flips for fun, or profit?" in *Proc. 22nd Int. Conf. World Wide Web*, D. Schwabe, V. A. F. Almeida, H. Glaser, R. Baeza-Yates, and S. B. Moon, Eds., Rio de Janeiro, Brazil, May 2013, pp. 989–998.

- [30] F. Quinkert, M. Degeling, J. Blythe, and T. Holz, "Be the phisher—Understanding users' perception of malicious domains," in *Proc. 15th ACM Asia Conf. Comput. Commun. Secur.*, H. Sun, S. Shieh, G. Gu, and G. Ateniese, Eds., Taipei, Taiwan, Oct. 2020, pp. 263–276.
- [31] P. Kintis, N. Miramirkhani, C. Lever, Y. Chen, R. Romero-Gómez, N. Pitropakis, N. Nikiforakis, and M. Antonakakis, "Hiding in plain sight: A longitudinal study of combosquatting abuse," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, B. Thuraisingham, D. Evans, T. Malkin, and D. Xu, Eds., Dallas, TX, USA, Oct. 2017, pp. 569–586.
- [32] P. Agten, W. Joosen, F. Piessens, and N. Nikiforakis, "Seven months' worth of mistakes: A longitudinal study of typosquatting abuse," in *Proc. Netw. Distrib. Syst. Secur. Symp.*, San Diego, CA, USA, 2015, pp. 1–13.
- [33] (2024). *GitHub—Elceef/Dnstwist*. [Online]. Available: <https://github.com/elceef/dnstwist>
- [34] D. Kim, H. Cho, Y. Kwon, A. Doupe, S. Son, G.-J. Ahn, and T. Dumitras, "Security analysis on practices of certificate authorities in the HTTPS phishing ecosystem," in *Proc. ACM Asia Conf. Comput. Commun. Secur.*, J. Cao, M. H. Au, Z. Lin, and M. Yung, Eds., Hong Kong, May 2021, pp. 407–420.
- [35] A. Drichel, V. Drury, J. von Brandt, and U. Meyer, "Finding phish in a haystack: A pipeline for phishing classification on certificate transparency logs," in *Proc. 16th Int. Conf. Availability, Rel. Secur.*, D. Reinhardt and T. Müller, Eds., Aug. 2021, pp. 1–12.
- [36] (2024). *VirusTotal Code Insight*. [Online]. Available: <https://blog.virustotal.com/2023/04/introducing-virustotal-code-insight.html>
- [37] F. Trad and A. Chehab, "Prompt engineering or fine-tuning? A case study on phishing detection with large language models," *Mach. Learn. Knowl. Extraction*, vol. 6, no. 1, pp. 367–384, Feb. 2024.
- [38] R. Meng, M. Mirchev, M. Böhme, and A. Roychoudhury, "Large language model guided protocol fuzzing," in *Proc. Netw. Distrib. Syst. Secur. Symp.*, 2024, pp. 1–17.
- [39] R. Liu, Y. Lin, X. Teoh, G. Liu, Z. Huang, and J. S. Dong, "Less defined knowledge and more true alarms: Reference-based phishing detection without a pre-defined reference list," in *Proc. 33rd USENIX Secur. Symp.*, D. Balzarotti and W. Xu, Eds., Philadelphia, PA, USA, 2024, pp. 523–540.
- [40] S. Saha Roy and S. Nilizadeh, "PhishLang: A lightweight, client-side phishing detection framework using MobileBERT for real-time, explainable threat mitigation," 2024, *arXiv:2408.05667*.
- [41] (2024). *Chrome DevTools Protocol*. [Online]. Available: <https://chromedevtools.github.io/devtools-protocol/>
- [42] J. Wei, X. Wang, D. Schuurmans, M. Bosma, B. Ichter, F. Xia, E. Chi, Q. Le, and D. Zhou, "Chain-of-thought prompting elicits reasoning in large language models," 2023, *arXiv:2201.11903*.
- [43] (2024). *OpenPhish*. [Online]. Available: <https://openphish.com/>
- [44] (2024). *PhishTank*. [Online]. Available: <https://phishtank.org/>
- [45] H. Nakano, D. Chiba, T. Koide, N. Fukushima, T. Yagi, T. Hariu, K. Yoshioka, and T. Matsumoto, "Canary in Twitter mine: Collecting phishing reports from experts and non-experts," in *Proc. 18th Int. Conf. Availability, Rel. Secur.*, Benevento, Italy, Aug. 2023, p. 6.
- [46] (2024). *Azure Cognitive Service for Vision With OCR and AI | Microsoft Azure*. [Online]. Available: <https://azure.microsoft.com/en-us/products/cognitive-services/vision-services>
- [47] (2024). *Mimino666/Langdetect: Port of Google's Language-Detection Library to Python*. [Online]. Available: <https://github.com/Mimino666/langdetect>
- [48] V. Le Pochat, T. Van Goethem, S. Tajalizadehkhoob, M. Korczynski, and W. Joosen, "TRANCO: A research-oriented top sites ranking hardened against manipulation," in *Proc. 26th Annu. Netw. Distrib. Syst. Secur. Symp.*, San Diego, CA, USA, 2019, pp. 1–15.
- [49] S. Marchal, J. François, R. State, and T. Engel, "PhishStorm: Detecting phishing with streaming analytics," *IEEE Trans. Netw. Service Manage.*, vol. 11, no. 4, pp. 458–471, Dec. 2014.
- [50] (2024). *Azure OpenAI Service—Advanced Language Models | Microsoft Azure*. [Online]. Available: <https://azure.microsoft.com/en-us/products/cognitive-services/openai-service>
- [51] G. DeepMind. (2024). *Gemini—Google DeepMind*. [Online]. Available: <https://deepmind.google/technologies/gemini/>
- [52] R. Liu, Y. Lin, Y. Zhang, P. H. Lee, and J. S. Dong, "Knowledge expansion and counterfactual interaction for reference-based phishing detection," in *Proc. 32nd USENIX Secur. Symp.*, Anaheim, CA, USA, J. A. Calandrino and C. Troncoso, Eds., 2023, pp. 4139–4156.
- [53] K. Tian, S. T. K. Jan, H. Hu, D. Yao, and G. Wang, "Needle in a haystack: Tracking down elite phishing domains in the wild," in *Proc. Internet Meas. Conf.*, Boston, MA, USA, Oct. 2018, pp. 429–442.
- [54] T. Koide, N. Fukushima, H. Nakano, and D. Chiba, "PhishReplicant: A language model-based approach to detect generated squatting domain names," in *Proc. Annu. Comput. Secur. Appl. Conf.*, Austin, TX, USA, Dec. 2023, pp. 1–13.
- [55] Qroq. (2024). *GROQ is Fast AI Inference*. [Online]. Available: <https://groq.com/>
- [56] S. Y. Zheng and I. Becker, "Checking, nudging or scoring? Evaluating e-mail user security tools," in *Proc. 19th Symp. Usable Privacy Secur.*, Anaheim, CA, USA, P. G. Kelley and A. Kapadia, Eds., 2023, pp. 57–76.
- [57] P. Omrani, A. Hosseini, K. Hooshanfar, Z. Ebrahimian, R. Toosi, and M. Ali Akhaee, "Hybrid retrieval-augmented generation approach for LLMs query response enhancement," in *Proc. 10th Int. Conf. Web Res. (ICWR)*, Apr. 2024, pp. 22–26. [Online]. Available: <https://api.semanticscholar.org/CorpusID:269953840>
- [58] F. Perez and I. Ribeiro, "Ignore previous prompt: Attack techniques for language models," 2022, *arXiv:2211.09527*.
- [59] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," 2023, *arXiv:2302.12173*.
- [60] I. de Zarzà, J. de Curtò, G. Roig, P. Manzoni, and C. T. Calafate, "Emergent cooperation and strategy adaptation in multi-agent systems: An extended coevolutionary theory with LLMs," *Electronics*, vol. 12, no. 12, p. 2722, Jun. 2023. [Online]. Available: <https://www.mdpi.com/2079-9292/12/12/2722>
- [61] C. Fan, J. Chen, Y. Jin, and H. He, "Can large language models serve as rational players in game theory? A systematic analysis," in *Proc. 38th Conf. Artif. Intell. (AAAI)*, 36th Conf. Innov. Appl. Artif. Intell. (IAAI), 40th Symp. Educ. Adv. Artif. Intell. (EAAI), M. J. Wooldridge, J. G. Dy, and S. Natarajan, Eds., Vancouver, BC, Canada, Feb. 2024, pp. 17960–17967, doi: [10.1609/aaai.v38i16.29751](https://doi.org/10.1609/aaai.v38i16.29751).



TAKASHI KOIDE received the B.E., M.E., and Ph.D. degrees in informatics from Yokohama National University, in 2014, 2016, and 2021, respectively. He is currently a Researcher with NTT Security (Japan) KK, Tokyo, Japan.



HIROKI NAKANO received the B.E., M.S., and Ph.D. degrees in computer science from Yokohama National University, Japan, in 2016, 2018, and 2024, respectively. He was with Nippon Telegraph and Telephone Corporation (NTT), in 2018, he has been engaged in research and development on cybersecurity.



DAIKI CHIBA (Member, IEEE) received the B.E., M.E., and Ph.D. degrees in computer science from Waseda University, in 2011, 2013, and 2017, respectively. Since 2013, he has been with Nippon Telegraph and Telephone Corporation (NTT), where he has been engaged in research on cyber security through data analysis. He is currently a Senior Manager with NTT Security (Japan) KK, Tokyo, Japan. He is a member of IEICE.

...